DSI102 · INTRODUCTION TO DIGITAL TECHNOLOGY

Week 9

Cyber Attacks, Threats, and Vulnerabilities



Understanding how systems are targeted — and defended

DEFEND DIGITAL ASSETS

Dr. Nantapong Keandoungchun

A normal day — until an account is locked

A single unexpected sign-in alert can trigger a much larger security investigation.

OPENING SCENARIO

What would you check FIRST if your university account suddenly stopped working?

01 Verify the notice through an official channel

02 Do not follow an unknown sign-in link

03 Report suspicious activity promptly

From Week 8 protection to Week 9 threats

The same system can be studied from the defender's and attacker's perspectives.

WEEK 8 / DEFENSE

Firewall and segmentation
Endpoint patching and monitoring
Application access control
Backups and incident response

VS

WEEK 9 / THREATS

Unauthorized access attempts
Malware and credential theft
Traffic disruption and manipulation
Application and human weaknesses

A security control reduces risk; no single layer guarantees protection.

Recurring example: a university network

Follow student data across devices, networks, applications, and services.



Blue path: ordinary authorized request through interconnected systems.

Learning outcomes

At the end of this lecture, students can explain threats and choose relevant defenses.

Explain

Distinguish threat, vulnerability, exploit and risk.

Recognize

Identify malware and social engineering indicators.

Connect

Relate network attacks to Week 5–6 concepts.

Analyze

Explain basic application security weaknesses.

Investigate

Identify lessons from documented incidents.

Respond

Select preventive, detective and recovery controls.

Today’s learning journey

Start with the language of risk, then connect technical and human attack surfaces.

LECTURE SEQUENCE

01 Threats & risk

02 Malware

03 Phishing

04 Network attacks

05 Web attacks

06 Case studies

07 Response

Recurring context: university Wi-Fi → portal → student records.

What is a cyberattack?

A deliberate attempt to compromise confidentiality, integrity, or availability.

CONCEPT DEFINITION

CYBERATTACK

An intentional action that tries to gain unauthorized access, manipulate information, disrupt a service, or otherwise harm a digital system.

Target
Information, users, devices, services

Method
Technical, social, or combined

Outcome
The attempt may succeed or fail

Know the definition • classify the example • identify the control.

Why cyberattacks matter

Consequences extend beyond stolen passwords.

Students

Lost account access, exposed identity information, fraudulent messages.

Organizations

Service downtime, financial cost, privacy obligations.

Society

Disrupted critical services, reduced trust, wider ripple effects.



01

Threats, Vulnerabilities and Risk

Give precise names to the weaknesses, actions, and possible consequences.

Core security vocabulary

These terms describe different parts of a potential incident.

Asset

Something valuable: data, service, device, reputation.

Threat actor

A person or group able to cause harm.

Vulnerability

A weakness that could be exploited.

Attack vector

A route or method used to reach a target.

Exploit

Use of a vulnerability to produce a security effect.

Risk

Potential for loss from a threat and its consequences.

How a weakness becomes an incident

Separate the existence of a weakness from exploitation and impact.

ILLUSTRATIVE PROCESS



READ THE SEQUENCE Each stage represents a conceptual step; controls can interrupt the progression.

Threat ≠ vulnerability

One is a potential cause of harm; the other is a weakness.

THREAT

Example: an attacker seeks stolen student credentials.
It may use different techniques or targets.

VS

VULNERABILITY

Example: reused passwords or an unpatched service.
A weakness may exist before any attacker discovers it.

An exploit is one way a threat may take advantage of a vulnerability.

Attack surface

The more exposed interaction points, the more places security must be considered.

CONCEPT DEFINITION

ATTACK SURFACE

The collection of digital and physical points through which an unauthorized actor may try to enter, influence, or extract data from a system.

Devices
Laptops, phones, servers

Services
Websites, APIs, remote access

People
Accounts, decisions, credentials

Know the definition • classify the example • identify the control.

The CIA triad: what is at stake?

Most security outcomes can be related to three objectives.

Confidentiality

Only authorized people see personal or sensitive information.

Integrity

Information remains accurate and is changed only as authorized.

Availability

Services and data remain accessible when needed.

Why do attackers attack?

Different motivations can produce similar outward symptoms.

Financial gain

Fraud, extortion, account resale.

Espionage

Seeking valuable or sensitive information.

Disruption

Stopping a service or undermining operations.

Ideology

Attempting to advance a cause or draw attention.

Insider versus external threats

Trust level and location do not reliably indicate whether an action is safe.

INSIDER

Employee or student with legitimate access.
Examples: accidental sharing; misuse of privileges; compromised internal account.

VS

EXTERNAL

Actor outside the authorized organization.
Examples: credential theft attempt; scanning exposed services; traffic flooding.

Both intentional and accidental behavior can create security incidents.

Class activity: password reuse

A student uses the same password for a game account and the university portal.

DISCUSS · 90 SECONDS

Identify the asset, vulnerability, threat action, possible impact, and prevention.

ASSET
University account / records

WEAKNESS
Reused password

THREAT ACTION
Credential-stuffing attempt

DEFENSE
Unique password + MFA

Students should justify their reasoning rather than memorize an isolated term.

02



Malware and Ransomware

From deceptive software to self-spreading threats and business disruption.

Malware is a family, not one program

Malware describes software designed to harm or misuse systems.

Virus

Attaches to host content and propagates when executed.

Worm

Can propagate across systems without a user repeatedly copying it.

Trojan

Disguises its malicious purpose as legitimate content.

Ransomware

Blocks access to systems or data to extort a victim.

Spyware

Secretly collects information or activity.

Bot

Compromised device controlled for attacker-selected tasks.

Virus: depends on a host

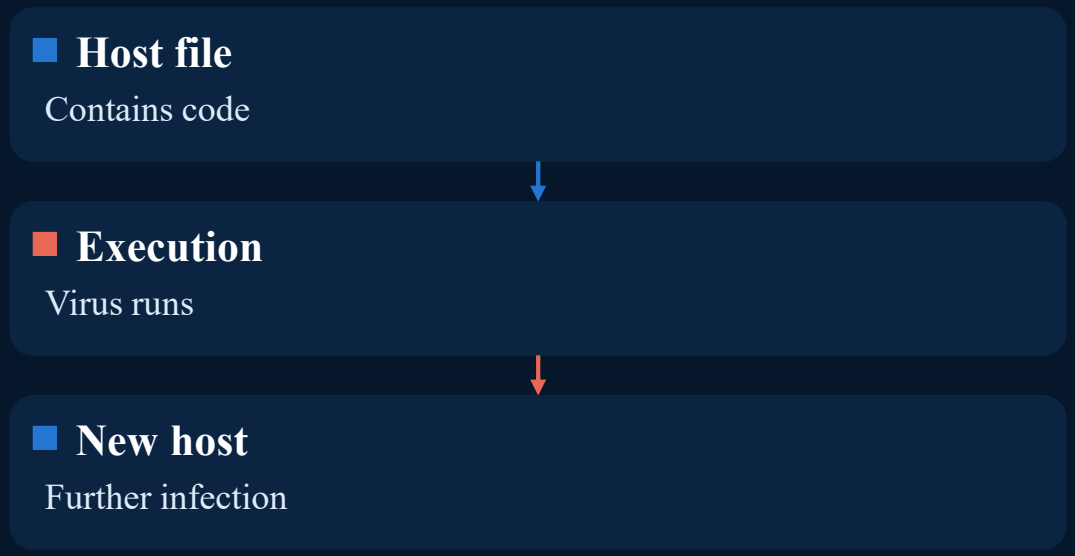
Virus propagation typically depends on infected executable content or files.

THREAT CONCEPT

VIRUS

Malicious code that inserts itself into a host file or program and reproduces when suitable host content runs.

CONCEPTUAL PATH



May modify or infect additional host files. • Often requires an execution or file-sharing pathway. • Antivirus, safe handling, and patching can reduce risk.

Worm: self-propagation matters

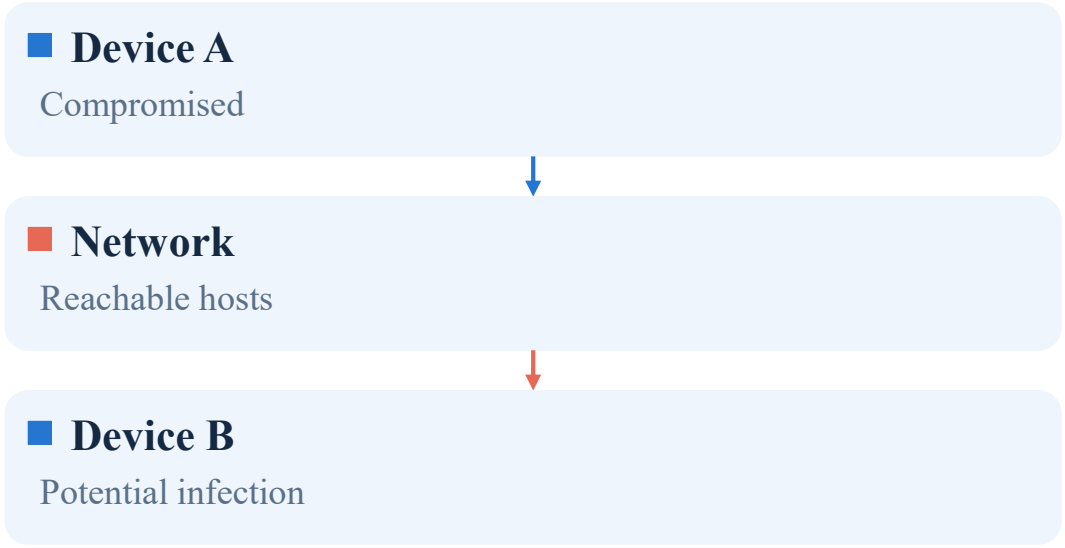
A worm can spread by exploiting connectivity or vulnerable services.

THREAT CONCEPT

WORM

A self-replicating malware category able to spread between systems without attaching to an existing file in the same way as a classic virus.

CONCEPTUAL PATH



May exploit unpatched network services. • Can move quickly across reachable systems. • Segmentation and updates help contain propagation.

Trojan: appearance creates misplaced trust

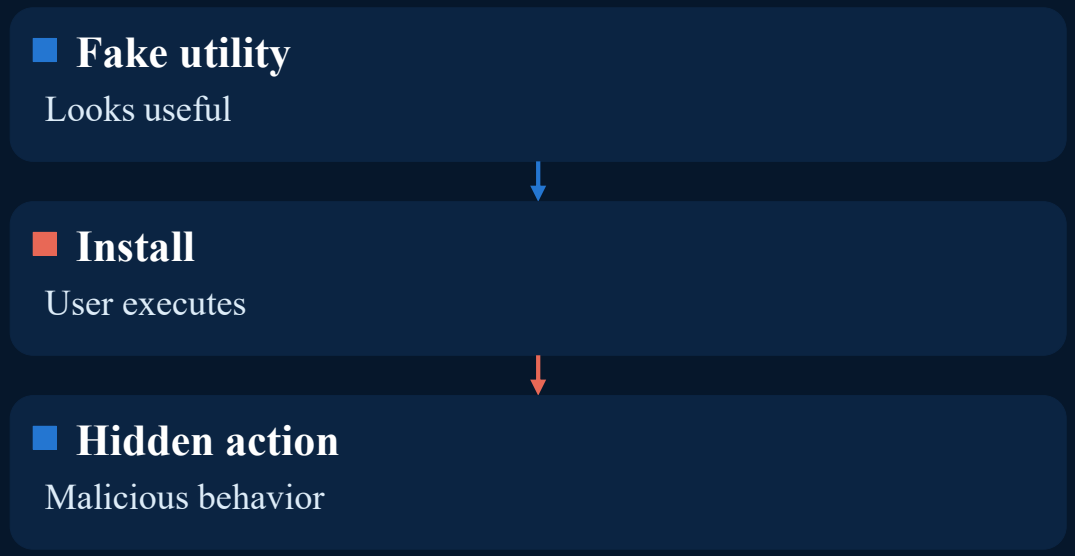
A Trojan is categorized by deception rather than self-replication.

THREAT CONCEPT

TROJAN

Malicious software presented as harmless or useful software to persuade users to install or run it.

CONCEPTUAL PATH



May arrive through misleading downloads. • Can carry spyware, backdoors, or other functions. • Verify software sources and installation permissions.

Virus, worm, and Trojan

Three labels describe different mechanisms.

VIRUS / WORM

Virus: relies on host content.
Worm: designed to replicate across reachable systems.
Both describe forms of propagation.

VS

TROJAN

Malicious function hidden behind apparently legitimate content.
It does not need to self-replicate.

A single malicious program may combine several behaviors.

Ransomware: availability and extortion

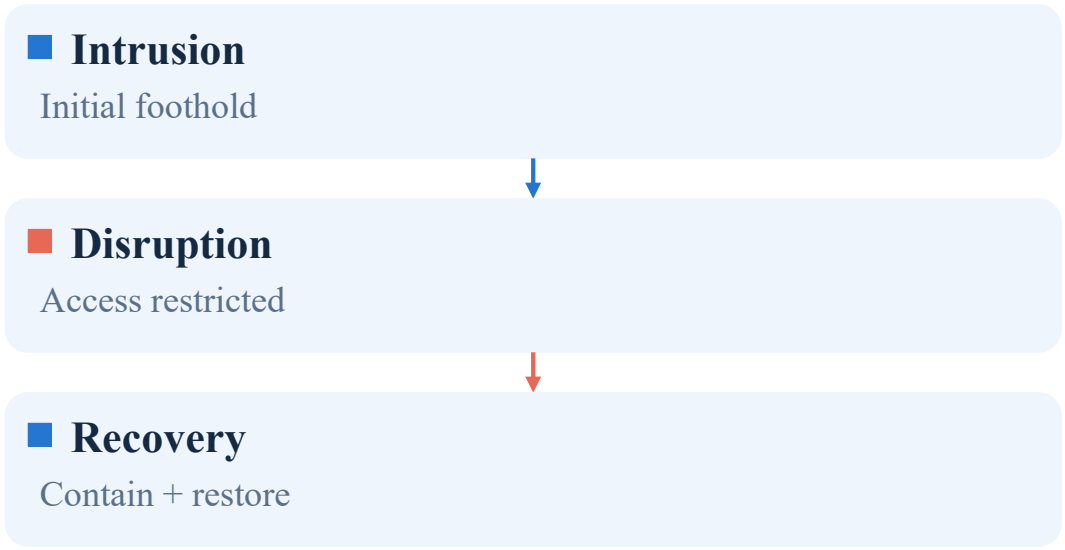
The purpose is to pressure victims by restricting access or threatening disclosure.

THREAT CONCEPT

RANSOMWARE

Malware associated with extortion, often involving encryption or disruption of data access; some incidents also include data theft.

CONCEPTUAL PATH



Can interrupt operations and learning services. • A ransom payment does not guarantee safe recovery. • Offline/isolated backups and response planning matter.

Illustrative ransomware incident chain

An attachment is one possible route; no individual step guarantees the next.

ILLUSTRATIVE PROCESS



READ THE SEQUENCE Each stage represents a conceptual step; controls can interrupt the progression.

Spyware versus keylogger

Both may threaten confidentiality, but their scopes differ.

SPYWARE

Broader category: software secretly gathers information or monitors activity.
May target browsing, system, or account data.

VS

KEYLOGGER

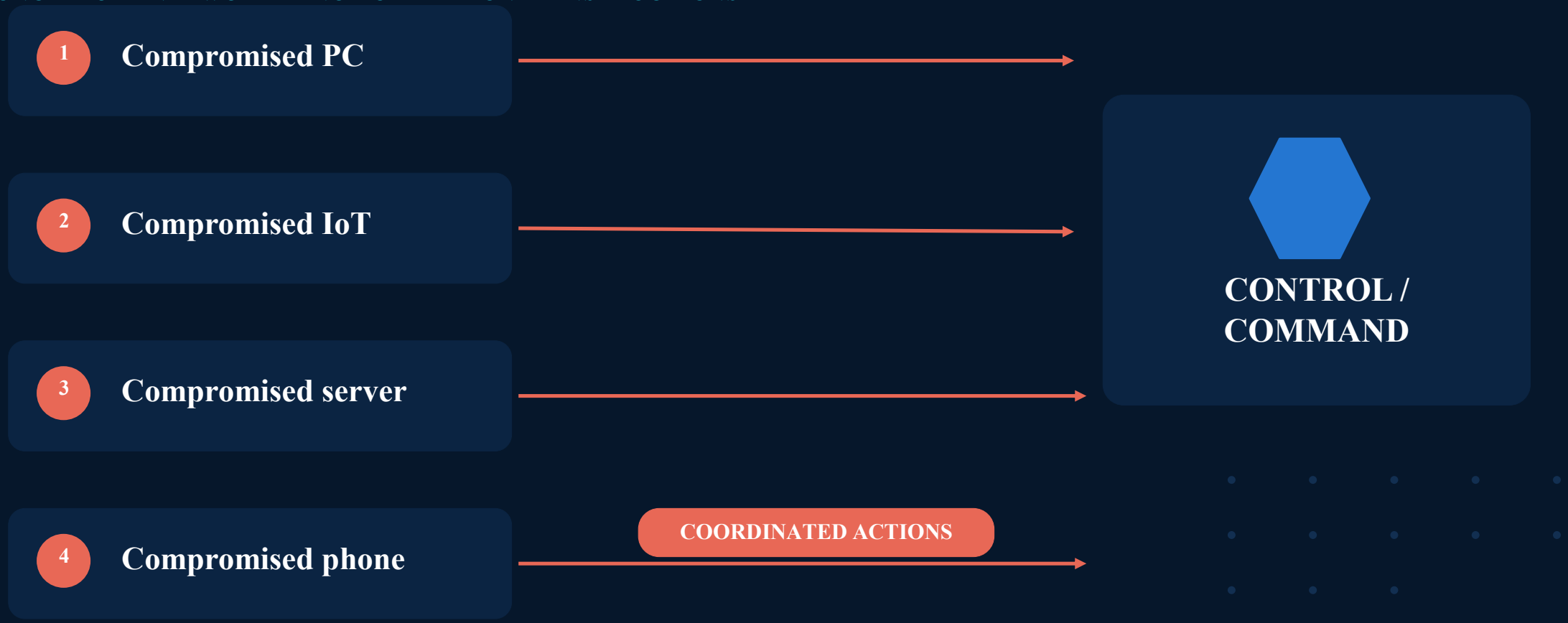
A capability that records keystrokes.
May be implemented in malicious or authorized monitoring software.

Classification depends on behavior and authorization, not only the name.

Botnets: one operator, many devices

Compromised devices may be coordinated into a network of bots.

CONCEPTUAL NETWORK — NOT OPERATIONAL INSTRUCTIONS



How malware may arrive

Recognize exposure routes without assuming every file or link is malicious.

Attachments

Suspicious messages may contain malicious files.

Untrusted apps

Unofficial installers can hide harmful components.

Unpatched services

Known software weaknesses can be exploited.

Removable media

Infected content may move between devices.

Defense is more than antivirus

Layer controls because no detection technology catches every threat.

Prevent

Patch, restrict privileges, verify sources.

Detect

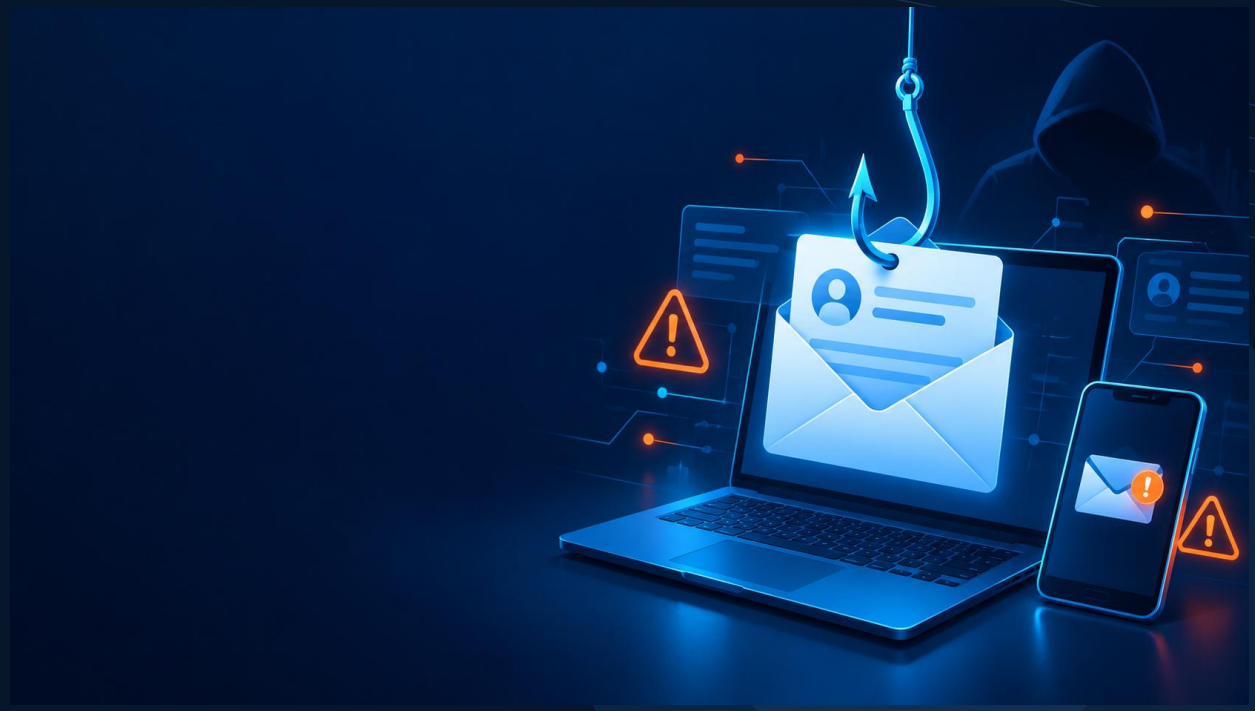
Endpoint alerts, suspicious behavior, system logs.

Contain

Isolate affected systems and limit lateral movement.

Recover

Restore from clean, tested backups.



03

Social Engineering and Phishing

People, trust, and decisions become part of the attack surface.

The human decision is the target

Social engineering influences people to share information or take risky action.

CONCEPT DEFINITION

SOCIAL ENGINEERING

Manipulating human trust, emotions, or expectations to cause disclosure, access, or actions that the person would not otherwise authorize.

Impersonation
Pretending to be trusted

Pressure
Urgency, fear or reward

Verification
Independent confirmation protects

Know the definition • classify the example • identify the control.

Four persuasion triggers

Recognizing pressure creates time for verification.

Urgency

“Your account will close in 10 minutes.”

Authority

“I am calling from university IT.”

Fear

“You will lose access unless you act.”

Reward

“Claim your scholarship voucher here.”

Phishing: deceptive messages

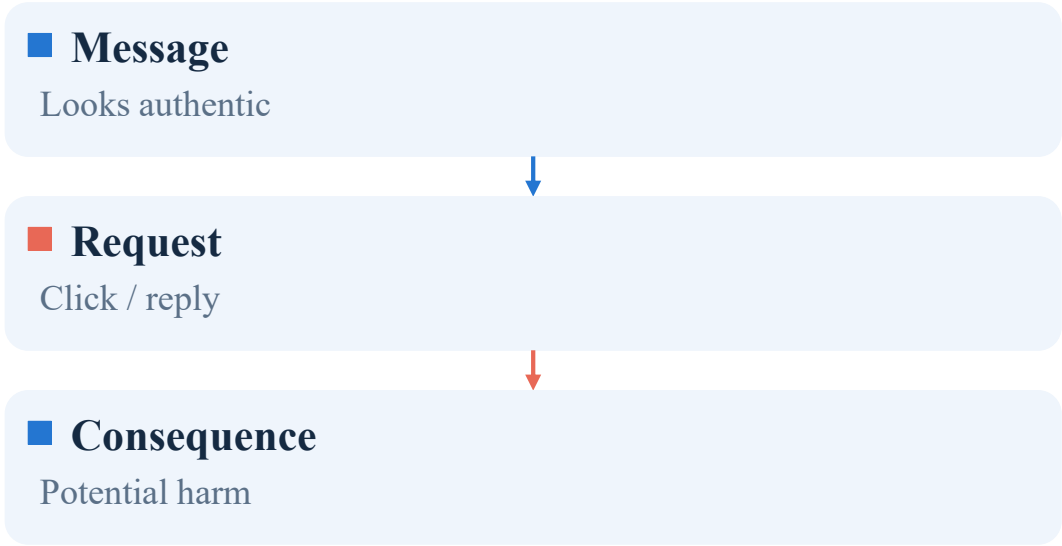
The message tries to move a recipient toward an unsafe action.

THREAT CONCEPT

PHISHING

A deceptive communication designed to trick someone into revealing information, sending money, or taking an action that benefits the sender.

CONCEPTUAL PATH



May impersonate a university, bank, colleague, or service. • Can use email, websites, attachments, or linked forms. • Verification should occur through a known trusted route.

Anatomy of a suspicious email

Examine the identity, link destination, requested action, and urgency.

FICTIONAL MESSAGE · FOR CLASSROOM USE

From: “Campus IT” <alerts@support-office.invalid>

Subject: URGENT: Your university account expires today

Your account will be disabled immediately. Confirm your password using the sign-in page linked below to avoid losing grades.

VERIFY ACCOUNT NOW

01
Unexpected deadline

02
Unverified sender

03
Password request

Do not use the example link: .invalid is reserved for nonfunctional examples.

Phishing comes in several forms

The target and communication channel can change.

Spear phishing

A tailored message for a specific person or small group.

Whaling

Targeted deception aimed at senior leaders.

Smishing

Phishing delivered through SMS or chat-like messages.

Vishing

Phishing conducted through voice communication.

Pretexting

Inventing a story or identity to obtain cooperation.

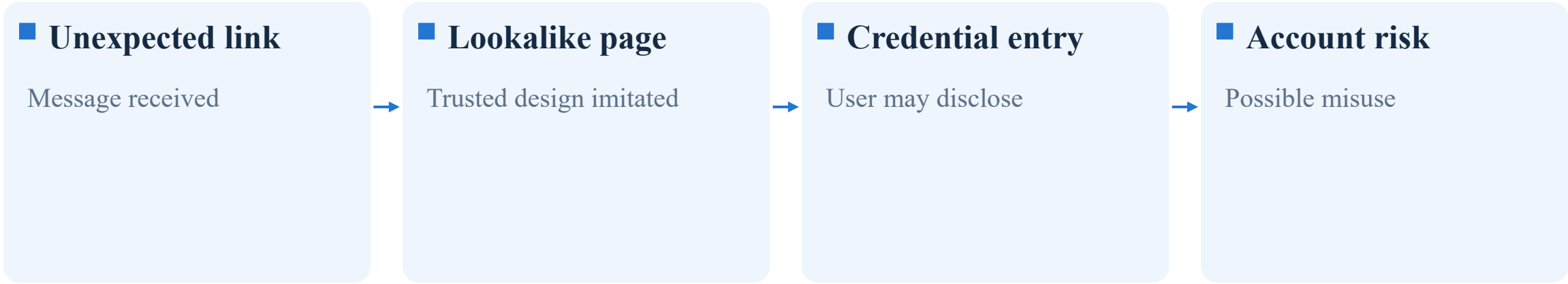
Baiting

Using an attractive offer to prompt unsafe action.

Fake login page: a trust problem

Brand-like appearance does not establish website identity.

ILLUSTRATIVE PROCESS



READ THE SEQUENCE Each stage represents a conceptual step; controls can interrupt the progression.

Credential theft can cross layers

A human-focused message can lead to application and data-level exposure.



Orange path: a suspected weakness or malicious action; defense layers still provide controls.

Legitimate or suspicious?

One visual clue is rarely enough; verify the actual request.

EXPECTED NOTICE

Seen inside the official portal.
No unexpected password request.
Can be confirmed with published support contacts.

VS

SUSPICIOUS NOTICE

Unexpected link and immediate deadline.
Requests credentials outside normal workflow.
Sender and site cannot be independently verified.

Use a separate, trusted communication path to check the claim.

Phishing workshop: the student portal

A message says “Reset your password now or your grades will disappear.”

DISCUSS · 90 SECONDS

What are three reasons to pause — and two safer next steps?

RED FLAG
Unsolicited urgency

RED FLAG
Threatening consequence

VERIFY
Open official portal independently

REPORT
Contact known IT support

Students should justify their reasoning rather than memorize an isolated term.

04



Network-Based Attacks

Availability, trust, and data flow across connected systems.

Normal traffic: request and response

The legitimate communication path provides a reference model.



Blue path: ordinary authorized request through interconnected systems.

DoS: exhausting a service

A denial-of-service event targets availability.

THREAT CONCEPT

DoS

An attempt to make a service unavailable or degraded by overwhelming resources or otherwise interfering with normal operation.

CONCEPTUAL PATH

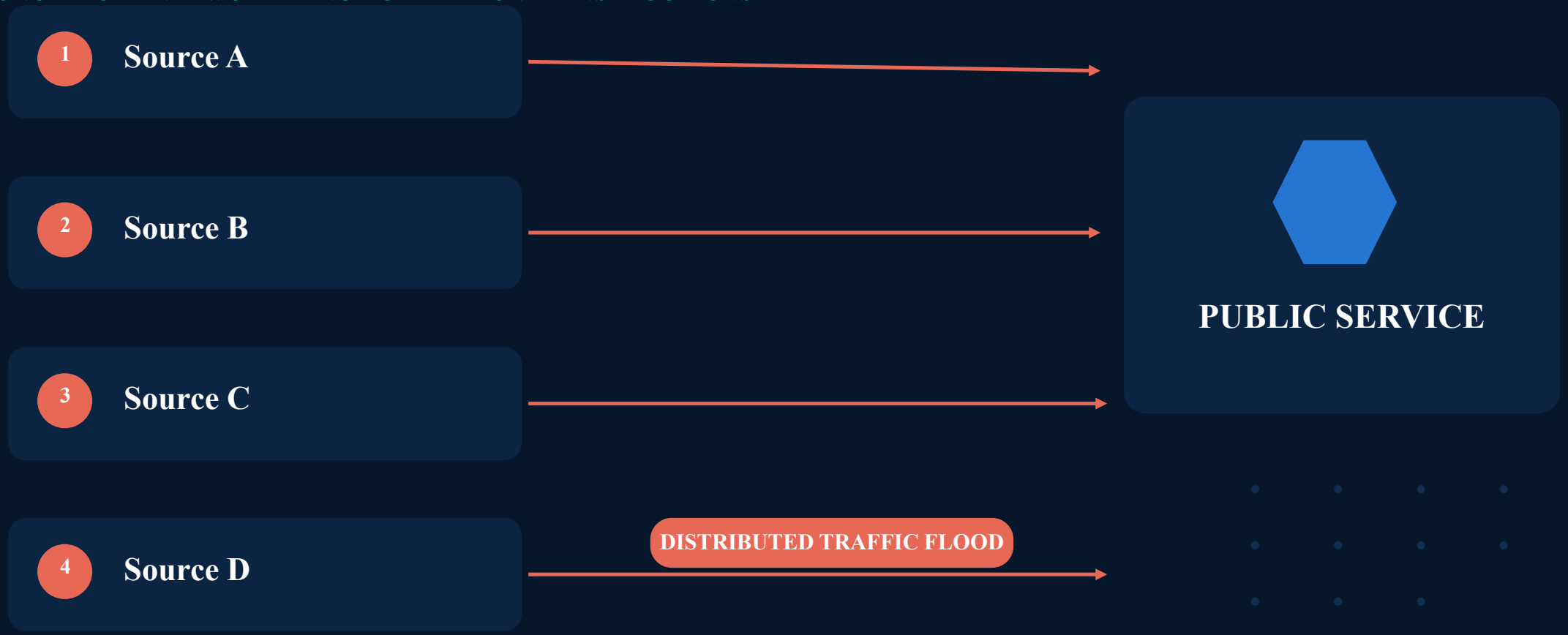


The target may be a service, link, or infrastructure component. • Legitimate users experience delay or failure. • Rate controls and resilient architecture can reduce some effects.

DDoS: traffic from many sources

Distributed sources can create larger, harder-to-filter disruption.

CONCEPTUAL NETWORK — NOT OPERATIONAL INSTRUCTIONS



DoS versus DDoS

The key distinction is how the disruptive activity is distributed.

DoS

One source or limited origin of disruptive activity. May exhaust bandwidth, connection capacity, or application resources.

VS

DDoS

Multiple distributed sources participate. Mitigation often relies on upstream filtering, capacity, and coordinated response.

A large amount of traffic alone is not proof of an attack.

Man-in-the-Middle concept

An attacker attempts to observe or alter communication between parties.



Modern TLS helps protect contents and detect tampering when correctly implemented and validated.

Network sniffing and encryption

Observing traffic is not the same as reading protected content.

UNPROTECTED TRAFFIC

Network observers may be able to read transmitted application data when the protocol lacks encryption.

VS

ENCRYPTED TRAFFIC

An observer may see connection metadata, but correctly protected application content should remain confidential.

Encryption protects content; endpoint trust and certificate validation still matter.

Spoofing: misleading identity or context

Different protocols offer different types of identifiers.

IP spoofing

A packet carries a forged source IP address.

ARP spoofing

Misleading local address-mapping information.

DNS spoofing

False name-resolution information redirects a lookup.

Email spoofing

Message headers may misrepresent the sender.

DNS: correct result or redirection?

Name resolution connects a requested service name with an IP address.

ILLUSTRATIVE PROCESS

Portal name

User requests name

→

DNS answer

May be legitimate or false

→

Destination

Browser connects

→

Validation

Identity checks matter

READ THE SEQUENCE Each stage represents a conceptual step; controls can interrupt the progression.

Session hijacking and password abuse

Attackers may misuse ongoing sessions or valid credentials.

Session hijacking

Unauthorized use of a valid session or token.

Credential stuffing

Automated attempts using previously exposed credentials.

Weak passwords

Simple or reused passwords increase exposure.

Controls

MFA, secure sessions, rate limits, monitoring.

Map network threats to defenses

A layer is effective when its control matches the problem.

THREAT / INCIDENT	PRIMARY CONCERN	EXAMPLE DEFENSES
DDoS	Availability	Traffic management; response planning
MITM / eavesdropping	Confidentiality / integrity	TLS; trusted configuration
DNS manipulation	Destination trust	Secure resolution; validation
Credential misuse	Account trust	MFA; monitoring; unique passwords

A mapping is a starting point; real incidents may involve several interconnected security layers.

05



Web and Application Weaknesses

When trusted software accepts untrusted input or grants excessive access.

Applications have their own attack surface

Correct networking does not guarantee correct application behavior.

Inputs

Forms, uploads, API requests, search fields.

Identity

Accounts, passwords, tokens, sessions.

Permissions

Roles, records, functions, and access rights.

Components

Libraries, dependencies, and server configuration.

SQL injection: unsafe query construction

Data must not be treated as trusted database instructions.



Use parameterized queries, appropriate privileges, and tested input handling.

XSS: untrusted content reaches a browser

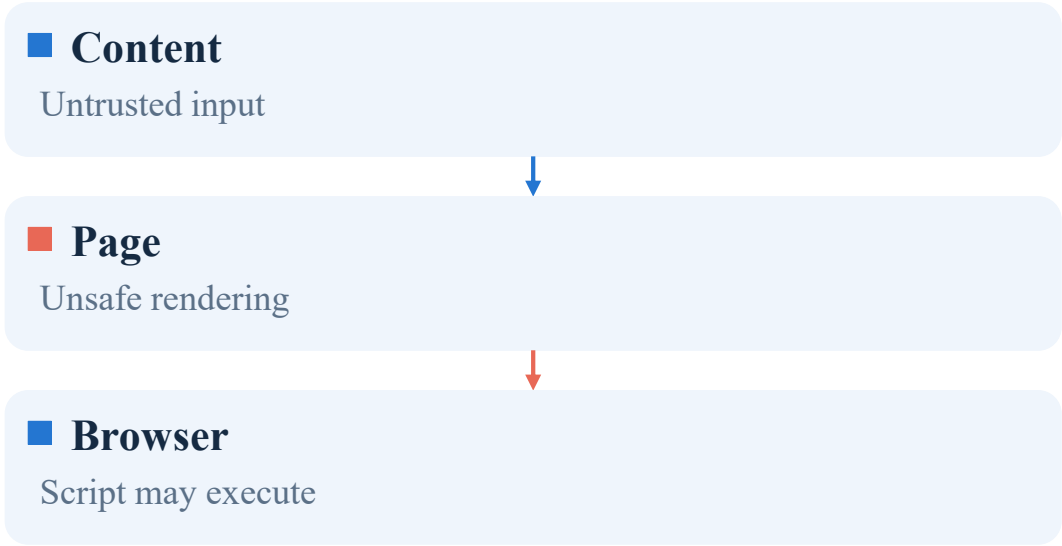
An application must handle user-supplied content in the correct context.

THREAT CONCEPT

XSS

Cross-site scripting occurs when an application allows untrusted content to be interpreted as executable script in another user's browser.

CONCEPTUAL PATH



Can affect a user viewing a vulnerable page. • Context-aware output encoding is a key protection. • Content security policy can reduce some impacts.

CSRF: unwanted action through a user browser

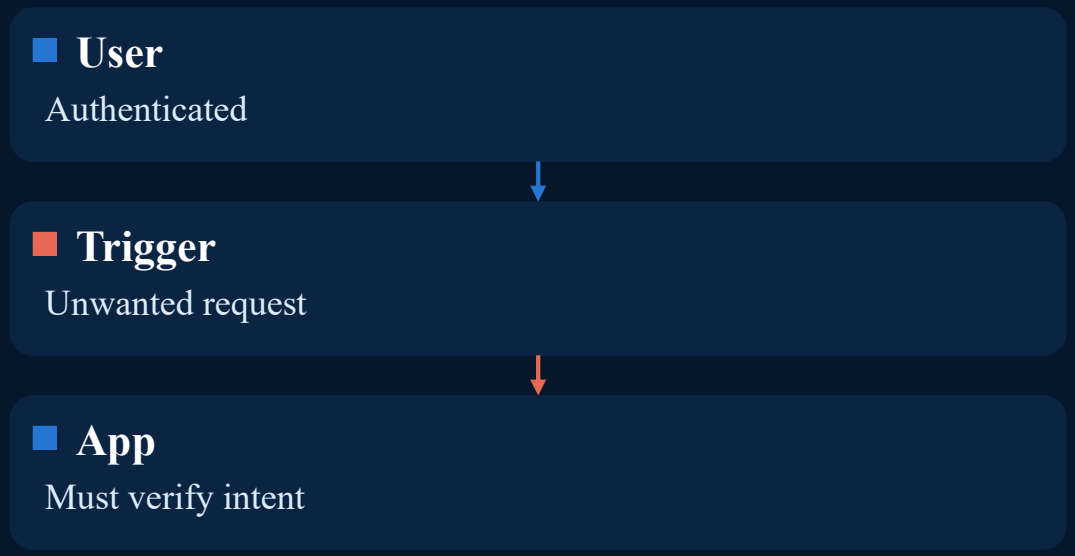
A site should verify that state-changing requests are intended.

THREAT CONCEPT

CSRF

Cross-site request forgery tricks an authenticated browser into making an unwanted request to a target application.

CONCEPTUAL PATH



May abuse automatically included authentication context. • Anti-CSRF tokens and SameSite cookies reduce risk. • Sensitive actions may require reauthentication.

Authentication versus authorization

A valid login does not grant unrestricted access.

AUTHENTICATION

Question: Who are you?
Example: verify the student account with a secure sign-in process.

VS

AUTHORIZATION

Question: What may you do?
Example: a student can view only their own academic record.

Both controls are necessary; authentication alone does not enforce data ownership.

Broken access control

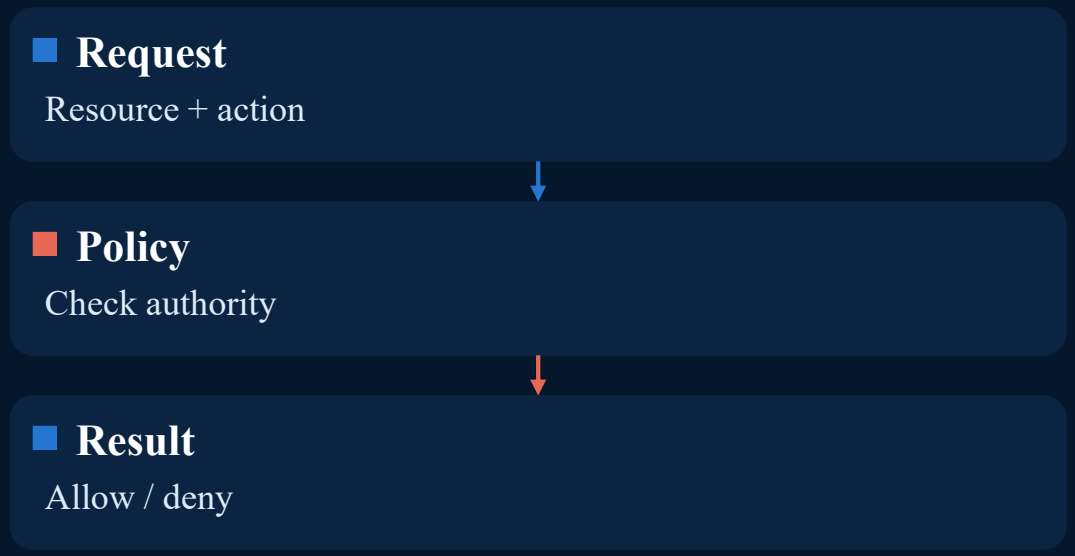
Application checks must enforce permissions on every relevant request.

THREAT CONCEPT

ACCESS CONTROL

Security checks deciding whether an authenticated or unauthenticated actor may perform an action on a particular resource.

CONCEPTUAL PATH

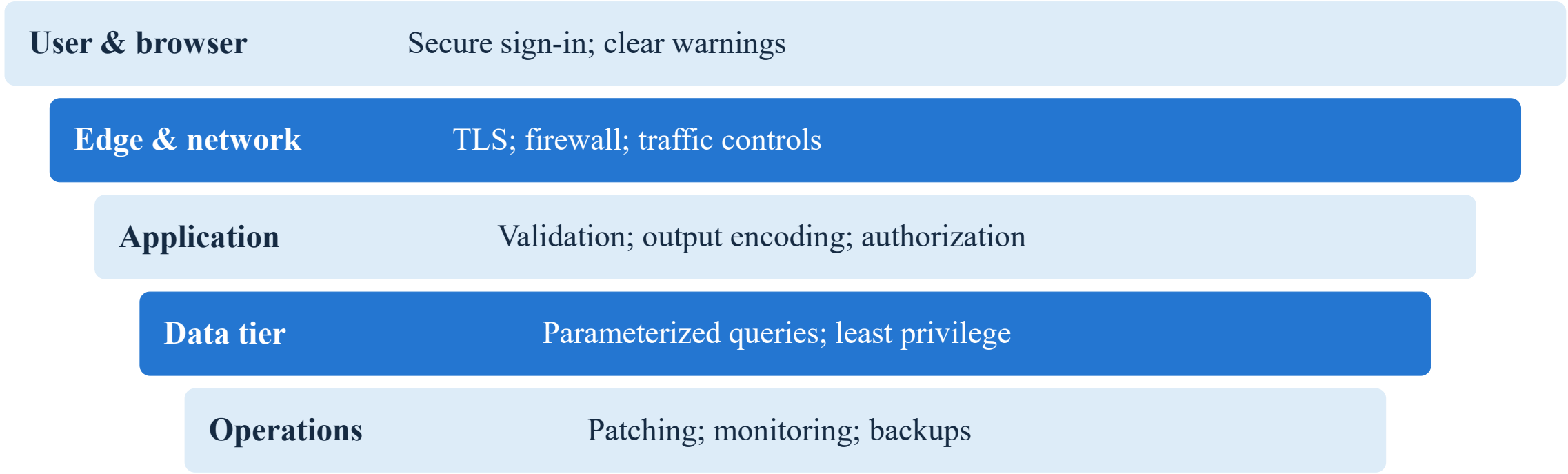


Permissions must be checked server-side. • A hidden interface button is not a security boundary. • Apply least privilege and test role boundaries.

Secure web application architecture

Protection works as a stack of independent safeguards.

EDITABLE LAYER MODEL



Multiple independent controls can limit the impact when an earlier safeguard fails.

Check your application security model

Match each issue to its main control.

1. SQL injection: which safe database programming approach is central?
2. XSS: what should happen to untrusted output?
3. CSRF: how can an application verify user intent?
4. Broken access control: where must permissions be enforced?

PAIR DISCUSSION • EXPLAIN YOUR CHOICE



06

Documented Cyber Incidents

Use evidence, not speculation, to connect weaknesses with consequences.

WannaCry (2017): a global ransomware outbreak

Worm-like propagation exploited already-patched Windows SMB vulnerabilities.

MAY 2017

WHAT HAPPENED

Ransomware encrypted files and spread among vulnerable Windows systems.

Known weakness

Windows SMB vulnerability

Available defense

MS17-010 update

Observed impact

Disruption and inaccessible data

Patch management, segmentation, and tested backups are essential.

WannaCry: where defense could intervene

Multiple independent controls reduce spread and recovery consequences.

Before

Asset inventory; security updates; remove unnecessary exposed services.

During

Endpoint alerts; isolation; segmentation; incident coordination.

After

Restore from tested backups; investigate root cause; improve patch verification.

Equifax (2017): unpatched application risk

An unpatched Apache Struts component contributed to a major data breach.

2017

WHAT HAPPENED

Attackers exploited a web application weakness, with sensitive consumer information exposed.

Exposure

Unpatched web application

Weaknesses

Insufficient patch verification; segmentation gaps

Impact

Personal information exposed

Verify patch completion, constrain data access, and detect unusual activity.

Colonial Pipeline (2021): digital disruption

Ransomware affecting IT systems led to a temporary pipeline shutdown.

MAY 2021

WHAT HAPPENED

The FBI attributed the compromise to DarkSide ransomware. Colonial paused pipeline operations as part of its response.

Affected environment

Corporate IT network

Operational decision

Pipeline operations halted

Outcome

Broader fuel-supply disruption

Business continuity and incident coordination matter alongside technical recovery.

Case studies: connect incident to security layers

Each real event supports more than one defensive lesson.

THREAT / INCIDENT	PRIMARY CONCERN	EXAMPLE DEFENSES
WannaCry	Endpoint + network	Patch; segment; detect; recover
Equifax	Application + data	Patch verification; access control
Colonial Pipeline	IT + operations	Contain; coordinate; business continuity

A mapping is a starting point; real incidents may involve several interconnected security layers.

07



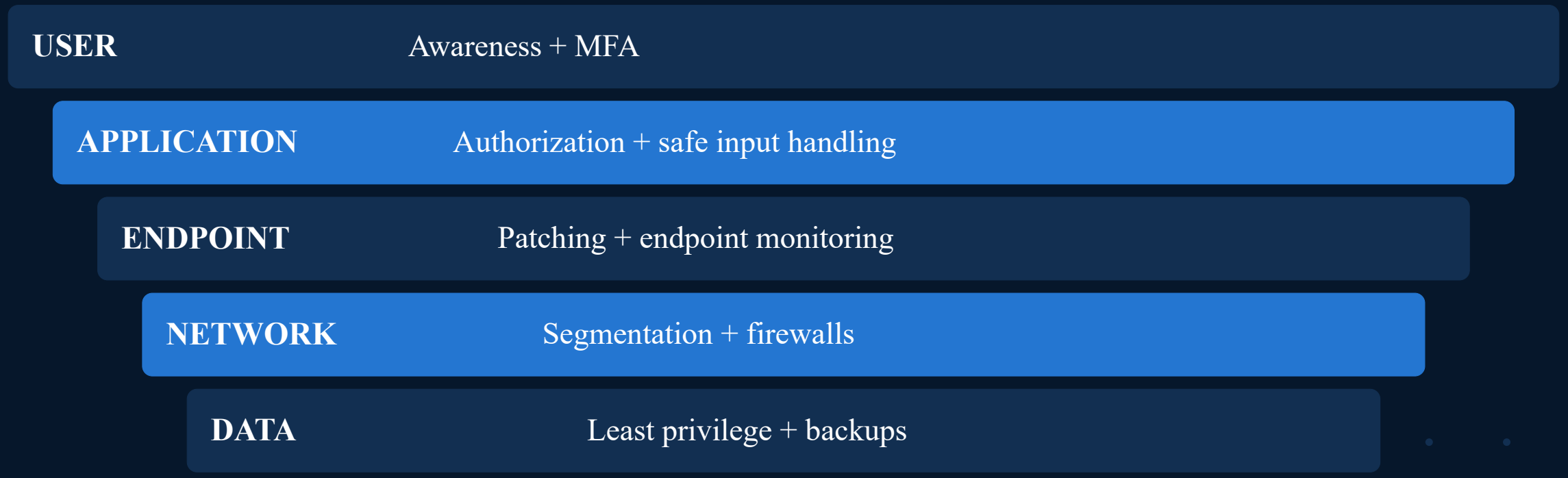
Prevention, Response and Review

Use the Week 8 layers to reduce incident likelihood and impact.

Defense in depth: controls work together

Security architecture should not depend on a single checkpoint.

EDITABLE LAYER MODEL



Multiple independent controls can limit the impact when an earlier safeguard fails.

Prevent • Detect • Respond • Recover

Four different functions form one coordinated security capability.

Prevent

Remove weaknesses and reduce opportunities.

Detect

Notice anomalies and validate evidence.

Respond

Contain activity and preserve critical services.

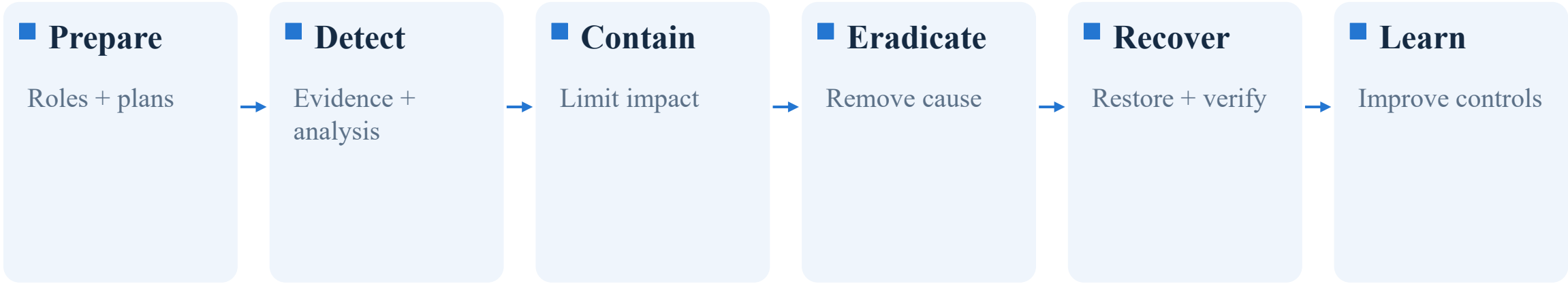
Recover

Restore operations and improve resilience.

Incident response: an introductory cycle

Exact phase names vary across professional frameworks.

ILLUSTRATIVE PROCESS



READ THE SEQUENCE Each stage represents a conceptual step; controls can interrupt the progression.

University scenario: portal unavailable

Multiple students report failed access after suspicious account notices.

DISCUSS · 90 SECONDS

What should the university team do before concluding that this is a cyberattack?

VERIFY
Confirm service symptoms and logs

TRIAGE
Check outage versus malicious activity

CONTAIN
Protect accounts and affected systems

COMMUNICATE
Use trusted status channels

Students should justify their reasoning rather than memorize an isolated term.

Five questions to take away

Explain your answer using a concrete example or named defensive layer.

1. Threat or vulnerability: which one is the weakness?
2. Why can ransomware affect availability?
3. How is phishing different from a network flood?
4. Why does HTTPS not make a site automatically trustworthy?
5. What protects recovery if prevention fails?

PAIR DISCUSSION • EXPLAIN YOUR CHOICE

Cybersecurity is a connected system

Understand the asset. Identify the weakness. Recognize the threat. Select the controls.

The system is interconnected.

So must be our security thinking.

01
Threat ≠ vulnerability

02
Attacks cross technical and human layers

03
Prevention + detection + response + recovery

04
Secure design must be continually maintained

NEXT: INFORMATION SECURITY & ENCRYPTION